

Operations Security Policy

Policy ID: HH-ISMS-05 **Version:** 1.0 **Effective Date:** 2026-08-29 **Owner:** Venkat Narasimha (Processbricks) **Review Cycle:** Annual **Last Reviewed:** 2026-08-29

Classification: Internal

1. Purpose

This policy governs the day-to-day operations that keep Haritha Hospitals ERPNext running: how we back up data, how we change things, how we watch for silent failures, how we patch, and how we hand off when an incident bleeds into operations.

Operations security is where most real outages are born. The 2026-08-29 prod backup silent-failure streak (LEARNINGS #79, #80, #113, #114) is the canonical case study: ops ran fine on paper for 8 days, but the actual state was “no offsite backup, no SHA256, no error log”. The 2026-08-29 unicorn --preload outage (LEARNINGS #153) is the second canonical case: an ops step (bench install-app) that “succeeded” but didn’t reach a healthy state because a sibling step (docker restart) was missed.

This policy makes both classes of failure — silent failure and partial deployment — explicitly impossible to repeat by mandating positive probes, mandatory sibling steps, and a tight feedback loop between operators and the heartbeat.

2. Scope

2.1 In scope

- **Backup operations** — cron schedules, retention, integrity, offsite rsync, restore drills.
- **Change management** — the runbook-driven flow that gates code/data/schema/infra changes (../05-process/05.1-change-management.md).
- **Logging and monitoring** — what is logged, retention, who reviews what, and how often.
- **Patch management** — Frappe / ERPNext / HRMS / OS / dependency updates; security-patch priority.
- **Vulnerability management** — periodic CVE checks on vendored Frappe/ERPNext and on Python deps pulled into haritha_hospital.
- **Incident response integration** — the handoff from operations (heartbeat, ops checks) to incident handling (../04-runbooks/04.4-incident-response.md).
- **Container orchestration hygiene** — image pruning, restart-after-install discipline, apps.txt/site_config consistency.

2.2 Out of scope

- **Application-level authentication and authorization** — see 02-access-control.
- **Cryptographic primitives and key storage** — see 04-cryptography.
- **Network perimeter and TLS termination** — see 06-communications-security.
- **Application-level incident triage** — see 07-incident-management (sibling policy).
- **DR restore procedure itself** — see ../04-runbooks/04.3-disaster-recovery.md.

3. Policy Statement

3.1 Backup operations (3-2-1, verified)

1. **3-2-1 mandatory.** Every production environment (pberpprod, pberpqa, pberpdev) has at least **3** copies of the database + site state, on **2** media (filesystem + git remote), with at

least **1** offsite. The offsite target is `venkat@135.125.196.35:/home/venkat/{pberpprod,pberpqa,pberpdev-erp}` reverses the direction (local = forever on venkat VPS; offsite = 7d on main VPS) — both directions satisfy 3-2-1.

2. **Cron cadence.** Production-class envs back up **4x/day** (0 */6 * * * IST — 00:00 / 06:00 / 12:00 / 18:00). Slot duration budget: ≤ 15 min (matches timeout 900 wrapper).
3. **Every backup script MUST:**
 - Run with `set -euo pipefail` (LEARNINGS #113).
 - Wrap `bench backup` in `timeout 900` (LEARNINGS #79).
 - Capture `${PIPESTATUS[0]}` exit code and bail loudly on failure.
 - Write a `.sha256` sidecar next to the `.tar.gz`.
 - `rsync` the bundle to offsite within the same slot.
 - End with a sentinel line `echo "$(date -Iseconds) BACKUP_OK sha=$SHA host=$HOST" >> "$LOG"`. A missing sentinel = silent failure (LEARNINGS #114).
4. **Positive-probe verification.** “Backup ran without error” is not enough. Daily ops heartbeat (`../04-runbooks/04.2-daily-ops.md` Step 2) compares the SHA256 of the local tarball against the offsite copy. A mismatch is a SEV-2 incident, not a “log it and move on”.
5. **Monthly restore drill.** The most recent tarball is restored to a scratch MariaDB and a sanity query (`SELECT COUNT(*) FROM \tabEmployee' etc.`) is compared against prod counts (acceptable drift window: ±5%). Document the diff in the daily log. Quarterly cadence for the full DR drill (per LEARNINGS #48) is in 08-business-continuity §3.4.
6. **Retention.** Local = 7 days rolling. Offsite = forever (per-environment subdirectory). Cold storage (Backblaze B2 or equivalent) = future, tracked in 08-business-continuity §6.
7. **Encryption at rest is a tracked exception** (see 04-cryptography §3.6 and Edge Case 7 in this policy). Offsite is a private VPS in Venkat’s name; single-operator trust boundary for v1.

3.2 Change management

1. **No change is anonymous.** Every change to QA or prod has a record (date, author, change type, risk, commit hash, backup timestamp, rollback plan) per `../05-process/05.1-change-management.md` §“Change record”.
2. **Mandatory pre-flight checklist** (`../05-process/05.1-change-management.md` §“Pre-flight checklist”) — 11 boxes including: backup verified fresh, offsite verified, fixtures exported, `docker restart` planned after `install-app` (LEARNINGS #153), `MEMORY.md` DB password re-verified (LEARNINGS #154), Venkat notified for prod. Any unticked box → STOP.
3. **Approval matrix.** Dev = solo. QA = Venkat review. Prod = Venkat approval + smoke plan. Single-operator model — Venkat is the only approver.
4. **Atomic cron edits** only — `heredoc` → `tempfile` → `crontab <file>` (LEARNINGS #77). Never `crontab -l | sed | crontab -` (LEARNINGS #78).
5. **Sibling steps are part of the change.** `bench install-app` is incomplete without `docker restart erp-{env}-backend-1`. `bench backup` is incomplete without offsite `rsync`. `bench export-fixtures` is incomplete without `fixtures = [...]` in `hooks.py` first (LEARNINGS #151). Runbooks that list one without the other are wrong.
6. **Post-deploy verification.** 5 curl URLs + 3 browser pages must pass before the change is declared “complete”. A failing check is a SEV-2 incident, not a “deploy succeeded with warnings”.

3.3 Logging and monitoring

1. **What we log:**
 - `Frappe tabError` Log — framework-level errors with traceback.
 - `Frappe tabVersion` — every doc save / submit / cancel (audit trail, per 01-info-security §3b Example 6).

- Nginx access + error logs (/var/log/nginx/, rotated daily).
 - Docker container stdout/stderr (docker logs --tail N).
 - SSH auth log (/var/log/auth.log) — for failed logins, sudo elevation, root attempts.
 - Backup cron log (/home/vijay/backups/logs/*.log).
 - Heartbeat probe log (/home/vijay/backups/logs/heartbeat.log or equivalent).
2. **Retention.** 30 days hot on disk, 1 year compressed in /home/vijay/logs/archive/. Future: ship to a longer-term log store (tracked in §6).
 3. **Review cadence:**
 - **Daily:** heartbeat probes (container health, backup freshness, cert expiry, disk space) — automated subagent runs at 08:30 IST.
 - **Weekly:** admin reviews failed-login rate, tabError Log spike pattern, backup log sentinel lines.
 - **Monthly:** full log archive, sanity-query the backup drill.
 - **Quarterly:** secret audit + tabUser reconciliation (02-access-control §5).
 4. **Alerting thresholds:**
 - **Backup slot missed** (no new bundle by 06:30 IST) → page on-call subagent immediately.
 - **tabError Log spike** (> 50 errors/hour on prod) → page Venkat (Telegram).
 - **Container restart** (RestartCount increase outside a known deploy) → log + check, page Venkat if prod.
 - **Disk > 90%** → subagent auto-prunes (LEARNINGS #91) + pages Venkat.
 - **SSL expiry < 14 days** → subagent force-renews (../04-runbooks/04.2-daily-ops.md Step 5).
 5. **No silent failures.** A failure that exits 0 with no useful log line is the highest-severity finding in this policy. LEARNINGS #113 / #114 are the canonical examples.

3.4 Patch management

1. **Three patch lanes** (priority order):
 - **Security:** OS-level (OpenSSL, glibc, sshd), Docker daemon, base Python 3.11. Apply within 7 days of upstream advisory.
 - **Stability:** Frappe / ERPNext / HRMS patch releases that fix known data-corruption bugs. Apply within 30 days; **always test on dev first** (LEARNINGS #44: HRMS v16.5.1+ breaks install — pin to v16.5.0 unless explicitly tested).
 - **Feature:** upstream minor versions. Apply within 90 days; test on dev → QA → prod; never during payroll week.
2. **Pin by digest, not tag** for production images. Tag is a moving target; digest is exact (frappe/erpnext@sha256:...).
3. **HRMS pin.** HRMS v16.5.0 is the last known-good release per LEARNINGS #44. Upgrading HRMS is a Venkat-approved change with a dry-run on dev → smoke → Venkat ack → prod.
4. **Pre-update dry-run:**
 - bench update --reset on dev first.
 - bench migrate on dev (verify tabError Log clean after).
 - bench export-fixtures --app haritha_hospital (LEARNINGS #151 — must have fixtures = [...] in hooks.py).
 - Smoke 5 URLs + 3 browser pages per ../05-process/05.1-change-management.md §“Smoke test (prod post-deploy)”.
5. **Rollback plan** for every patch. If a patch breaks prod, we must be able to revert to the prior image + restore from the most recent backup within RTO (1 hour, per 08-business-continuity §3).

3.5 Vulnerability management

1. **CVE checks:**

- **Weekly:** automated scan of vendored apps/{frappe,erpnext,hrms}/ against the upstream Frappe security advisories feed (manual until a CI job is wired — future).
 - **On PR:** pip-audit against the requirements of haritha_hospital (planned, future improvement).
 - **Ad-hoc:** on any reported CVE that names Frappe / ERPNext / HRMS / MariaDB / Redis.
2. **Dependency updates:**
 - haritha_hospital requirements.txt updates require: pip install --user <pkg> on dev → smoke 8-phase test (LEARNINGS #48) → Venkat review → QA → prod.
 - Prefer pinning to specific versions (frappe-client==1.2.3) over ranges.
 3. **Out of scope for v1:** third-party SaaS penetration tests, mobile-app security audit, network penetration test. Acknowledged limitation per 01-info-security §3a “Known GAPS”.

3.6 Incident response integration

1. **Heartbeat → incident handoff.** When a heartbeat probe fails the threshold, the sub-agent declares a SEV per ../04-runbooks/04.4-incident-response.md §“Severity levels” and routes:
 - SEV-1/2 → page Venkat (Telegram @Miles_Morales_12) immediately + open incident thread.
 - SEV-3 → log + queue for daily ops review.
 - SEV-4 → back of queue.
2. **Post-incident hand-back.** Operations resumes normal cadence only after Venkat ack on the all-clear Telegram message. Resume the heartbeat cron (it should not be paused during an incident unless Venkat explicitly asks).
3. **Post-mortem required** for SEV-1 and SEV-2 (../05-process/05.2-post-mortem.md). The 2026-08-29 500-outage is the canonical example.
4. **Lessons-learned loop.** Every SEV-1/2 incident writes at least one entry to .learnings/LEARNINGS.md (numbered, prefixed #1XX). Runbook updates are part of the close-out checklist.
5. **Single-responder caveat.** No formal on-call rotation (single-operator model). Backup contact is Venkat; subagents are advisory. If Venkat unreachable for > 1 hour during SEV-1, execute safest-known fix, document, notify when available.

3.7 Container orchestration hygiene

1. **apps.txt ↔ apps/ folder consistency** is checked in the pre-flight (../04-runbooks/04.1-deployment.md) and asserted in the heartbeat (apps.txt modtime vs apps/ dir listing). LEARNINGS #80, #89.
2. **Image pruning.** Weekly Sunday 04:00 IST cron runs docker image prune -a -f && docker system prune --volumes -f (LEARNINGS #91). Always dry-run first when modifying.
3. **Restart-after-install discipline.** After ANY bench install-app on a running container: docker restart erp-{env}-backend-1 is mandatory (LEARNINGS #153). bench restart alone is insufficient.
4. **Gunicorn-specific.** Gunicorn runs as PID 1 with --preload. New env vars / new Python packages / new apps require a backend container restart, not just bench restart.
5. **RestartCount assertion.** Heartbeat asserts RestartCount == 0 on erp-{env}-scheduler-1. Any drift triggers an alert.

3a. Current State (as of 2026-08-29)

What we have TODAY

Operational area	Component	Where it lives	Status
Backup	prod_backup.sh (hardened)	/home/vijay/scripts/prod_backup.sh	Live (post-2026-08-19 fix)
Backup	dev_backup.sh	/home/vijay/scripts/dev_backup.sh	Live, backup pending — known gap
Backup	qa_backup.sh	/home/vijay/scripts/qa_backup.sh	Live, backup pending — known gap
Backup	deverp_backup.sh (mirrors dev)	/home/venkat/scripts/deverp_backup.sh	Live
Backup	offsite rsync	venkat@135.125.196.35:/home/venkat/ftp/prod, pber	Live
Backup	SHA-256 sidecar	*.tar.gz.sha256 next to each tarball	Live (post-LEARNINGS #113 fix)
Backup	sentinel line	BACKUP_OK sha=... in cron log	Live (post-LEARNINGS #113 fix)
Change mgmt	Pre-flight checklist	../05-process/05.1-change-management.md \$“Pre-flight checklist”	Live
Change mgmt	Change record	docs/phase6/changes/Conv-YYYY-MM-DD.md	Convention; first run pending
Monitoring	Heartbeat cron	subagent @ 08:30 IST daily	Live
Monitoring	tabError Log review	daily ops runbook	Live
Monitoring	Cert expiry probe	daily ops runbook Step 5	Live
Monitoring	Disk space probe	daily ops runbook + LEARNINGS #91 weekly prune	Live
Monitoring	Container health probe	daily ops runbook Step 4	Live
Monitoring	Backup SHA-256 probe	daily ops runbook Step 2	Live
Patch mgmt	HRMS v16.5.0 pin	frappe/erpnext:v16.x + apps/hrms checkout	Pinned (LEARNINGS #44)
Patch mgmt	Custom app versioning	apps/haritha_hospital/looks.py	Live
Vulnerability	Weekly CVE scan	manual review of upstream advisories	Gap (future CI job)
Incident handoff	Telegram @Miles_Morales_12	SEV-1/2 immediate page	Live
Incident handoff	Post-mortem template	../05-process/05.2-post-mortem.md	Live (2026-08-29 example filled in)
Container hygiene	apps.txt ↔ apps/consistency	pre-flight + heartbeat modtime probe	Live
Container hygiene	Image prune	weekly Sunday 04:00 IST cron (LEARNINGS #91)	Live

Operational area	Component	Where it lives	Status
Container hygiene	Restart-after-install	runbook-mandated	Live (LEARNINGS #153)

What is WORKING

- **Backup cron is now reliable for prod.** Post-2026-08-18 hardening + apps.txt ghost cleanup, slot #1 + #2 of 2026-08-19 both PASSED with BACKUP_OK sha=... sentinel lines (LEARNINGS #79, #80, #113).
- **Offsite rsync is on a different SSH key** (/root/.openclaw/venkat_vps_key), separate from the VPS admin key. Blast radius is bounded.
- **Heartbeat detects silent failures.** RestartCount > 0 on erp-{env}-scheduler-1 would have caught the 2026-08-10..18 backup streak if it had been running; it's running now.
- **Pre-flight checklist gates deploys.** The 11-box list at ../05-process/05.1-change-management.md §“Pre-flight checklist” is the only path to prod — no deploy without it ticked.
- **Atomic cron install** (here doc + temp file) prevents the 2026-08-18 clobber race (LEARNINGS #77).
- **HRMS is pinned to v16.5.0** to avoid the v16.5.1+ repost_allowed_types install break (LEARNINGS #44).
- **Post-mortem discipline.** The 2026-08-29 500-outage is fully documented per template — 4 new lessons (#153, #154, reinforced #72, #46) plus runbook updates landed within 24h.

Known GAPS

1. **dev_backup.sh, qa_backup.sh, deverp_backup.sh are pre-hardening.** They don't have timeout 900 or \${PIPESTATUS[0]} capture. They run, but on edge-case errors could fail invisibly. **Risk:** medium — these envs are dev/QA so data loss is recoverable, but the script is a template that could be promoted by mistake. Tracked in ../04-runbooks/04.3-disaster-recovery.md §“Backup scripts”.
2. **No CI-side CVE scanner.** Weekly CVE review is manual. A pip-audit + Frappe advisory-fetch CI job is a future improvement (tracked in §9).
3. **No formal docs/phase6/changes/ directory.** The convention exists in the change-mgmt policy but no files have been written. Future: enforce on the next prod change.
4. **No log shipping to long-term storage.** Logs stay on disk for 30 days, then are gzip-archived locally. A 1-year+ store (e.g., a third log VPS or Backblaze B2) is a future improvement.
5. **Heartbeat is subagent-driven, not cron-driven.** A subagent at 08:30 IST runs the probes. If the subagent is unavailable (e.g., session limit hit), probes don't run. Future: a crontab-based heartbeat shell script as the authoritative fallback.
6. **No automated RestartCount paging for non-prod envs.** Currently dev/QA scheduler restarts log but don't page. Acceptable (no users), but should be flagged so the gap is visible.
7. **No DLP/secret-scan CI job** (cross-link 04-cryptography §3.5). Pre-commit hook runs on dev's machine only.
8. **Image-prune cron is on the main VPS only.** venkat@135.125.196.35 (offsite) has no prune cron. Disk on that VPS is at 60% today but growth is slower.

These gaps are explicit v1 scope decisions. Listing them is transparency, not apology.

3b. Concrete Examples (Haritha history)

Real ops incidents and near-misses that shaped this policy.

Example 1 — 2026-08-10..18 prod backup silent-failure streak (LEARNINGS #79, #80, #113, #114)

- **What happened.** `prod_backup.sh` ran 4x/day from 2026-08-10 through 2026-08-18. Every slot failed silently. No cron error, no `BACKUP_OK` sentinel, empty offsite rsync target. The on-call admin had no idea.
- **Root cause.** Two stacked bugs: (a) `bench backup --with-files` has no built-in timeout and a stale `apps.txt` `hrms` reference caused a 1-second `ModuleNotFoundError` exit (LEARNINGS #80); (b) `set -euo pipefail + $(ls *.tar.gz)` command-substitution trap swallowed any residual error (LEARNINGS #113). Neither alone would have been silent — both together were. The lack of a sentinel `BACKUP_OK sha=...` line (LEARNINGS #114) meant the log only showed starting and running markers.
- **Response.** 2026-08-18: Patched `prod_backup.sh` with `timeout 900 docker exec ... bench ... backup --with-files`, removed ghost `hrms` from `apps.txt` + `site_config.json`, added `PIPESTATUS[0]` exit capture, added `stderr tee` to `/tmp/backup-*.log`, added the `BACKUP_OK sha=$SHA host=$HOST` sentinel. Verified 2026-08-19 with two consecutive cron slots passing (`pberpprod_backup_20260819_000002.tar.gz` + `pberpprod_backup_20260819_060001.tar.gz`, both 1.03MB).
- **Policy lesson.** “Backups are running” $\neq$ “Backups are succeeding”. A positive probe (`sha256sum` matches between `local` and `offsite`) is the only assertion that matters. This is why §3.1.4 mandates the SHA256 cross-check as part of daily ops, and why §3.1.3 requires the sentinel line — it turns silent failure into loud failure.

Example 2 — 2026-08-29 gunicorn --preload outage (LEARNINGS #153, #46)

- **What happened.** After `bench install-app haritha_hospital` on running backend containers (both `pberpprod` and `pberpdev`), every HTTP request returned `ModuleNotFoundError: No module named 'haritha_hospital'` $\rightarrow$ HTTP 500. Both prod and dev down for ~30-60s each.
- **Root cause.** Gunicorn PID 1 with `--preload` flag freezes `sys.path` at startup; new packages installed afterwards are invisible until container restart. `bench restart` does NOT restart gunicorn (it only reloads the `bench` process), so the recovery required `docker restart erp-{env}-backend-1`.
- **Response.** Both backends restarted in parallel. Zero data loss. Post-incident: added a mandatory `docker restart` step to the post-install runbook (`../04-runbooks/04.1-deployment.md` Step “Phase 1 #6”).
- **Policy lesson.** “Deploy succeeded” $\neq$ “Service healthy”. A change is incomplete until the sibling step (`docker restart`) is also complete. §3.2.5 codifies sibling steps as part of the change. This is also why §3.3.4 mandates a post-deploy 5-URL + 3-page smoke that exercises the *running* process, not just the install exit code.

Example 3 — 2026-08-18 cron race condition (LEARNINGS #77, #78)

- **What happened.** Three agents concurrently editing the crontab with `crontab -l | sed ... | crontab -`. Each agent’s `crontab -l` returned whatever the previous agent most recently wrote. Last-writer-wins, no diff, no warning. Final state diverged from all three agents’ intents. Only 1 of 4 backup cron lines was correctly updated.
- **Root cause.** The crontab is shared system state; the `crontab -l | sed | crontab -` pattern has no transactional isolation.

- **Response.** New canonical pattern: `crontab <heredoc-tempfile>` from a backup-aware heredoc with `hash-before / hash-after` verification. Post-recovery crontab hash: `941eeefc977ae1aabb185e8a5a94c4dcdeed649d45ca67b72f0ba60e4a98127`. Pattern documented in LEARNINGS #77 and added to `../05-process/05.1-change-management.md` §“Common anti-patterns”.
- **Policy lesson.** Shared-state mutations (cron, secrets, config files) need the same care as DB writes: backup, verify, lock, audit. This is why §3.2.4 mandates atomic cron edits and §3.6.3 lists cron integrity as a weekly check.

Example 4 — 2026-08-19 dev-erp scheduler MySQL 1045 silent failure (LEARNINGS #87)

- **What happened.** `erpdev-scheduler-1` runs but every scheduled event silently fails with MySQL 1045 (access denied) for the site user `@172.30.0.5`. Backup cron is unaffected (uses container env var directly, not scheduler events). The scheduler has been in this state since at least 2026-08-19; the heartbeat caught it only when Venkat reviewed logs manually.
- **Root cause.** The MySQL grant for the site user is missing the scheduler container’s IP. The scheduler container does not crash — it just can’t execute scheduled tasks.
- **Response.** Pending — awaiting Venkat approval for a MySQL grant fix (see MEMORY.md “Active Open Follow-ups”). Until then, backup cron (which uses container env directly, not scheduler) remains the reliable data path.
- **Policy lesson.** “Container is up” $\neq$ “Container is functional”. LEARNINGS #88 taught us that `sites/<site>/logs/scheduler.log` is the canonical probe location for scheduler health — not `docker logs`, which doesn’t surface scheduler-internal errors. §3.3.1 codifies this probe source. The dev-erp 1045 is the operational form of “container is up, service is broken”, which is the exact failure mode the heartbeat is meant to catch.

Example 5 — 2026-08-21 heartbeat carry-forward drift (LEARNINGS #90)

- **What happened.** Daily heartbeat reported `Disk: 77% / 17G free` carried forward from Aug 20 06:00 IST for 26 hours. Actual current state: `95% / 4.1G free`. 13G growth unnoticed.
- **Root cause.** Carry-forward across >6h for drift-prone metrics (disk, memory, container count, log file size, `apps.txt` modtime) is dangerous. The heartbeat treated yesterday’s probe as today’s.
- **Response.** Rule added: for any drift-prone metric, fresh probe every ≤ 24 h. Disk, container count, `apps.txt` modtime all now probed live every heartbeat run. Quick-probe snippet added to LEARNINGS #90.
- **Policy lesson.** Heartbeats are not “carry yesterday’s number”. A heartbeat is a probe. §3.3.3 codifies the cadence.

Example 6 — 2026-08-21 disk near-full (LEARNINGS #91)

- **What happened.** Main VPS disk reached 95% on a 72G root. 13.4G reclaimable from dangling Docker images (94% of image storage).
- **Response.** Scheduled weekly Sunday 04:00 IST `docker image prune -a -f && docker system prune --volumes -f cron`. Safety: `docker image prune -a` removes ONLY images not used by any container (won’t touch the 13 active images).
- **Policy lesson.** Operations hygiene is a recurring cost, not a one-time cleanup. §3.7.2 mandates the prune cron as part of normal operations.

Example 7 — 2026-08-21 apps.txt ↔ apps/ folder drift (LEARNINGS #80, #89)

- **What happened.** apps.txt was modified 2026-08-20 17:53 IST to add hrms+payments, but a scheduler restart at 02:48 UTC triggered ModuleNotFoundError. pberp-scheduler-1 crash-looped with 5 restarts in 21 minutes. erp-{prod,qa,dev}-scheduler had the same drift but RestartCount=0 since 2026-08-19 — any restart would have crashed identically.
- **Root cause.** apps.txt ↔ apps/ folder drift; the scheduler crashed silently.
- **Response.** Apps.txt / site_config.json reconciliation added to pre-deploy checklist. Heartbeat now asserts scheduler container RestartCount == 0 as part of the daily ops probe.
- **Policy lesson.** “Config is in sync” is an assertion, not a property. Drift happens (LEARNINGS #80); the assertion catches it (LEARNINGS #89). §3.7.1 codifies this.

Example 8 — 2026-08-14 sub-agent verification gap (LEARNINGS #72)

- **What happened.** A subagent reported “ready” after editing an ssh heredoc for the offsite rsync script. The script was syntactically valid but the heredoc-escape inside a docker exec shell had unescaped backticks, causing the cron to expand a command before the heredoc was even written to file. Result: the offsite log filename was the literal output of date at heredoc-write time, not at rsync runtime.
- **Root cause.** Subagent verified “the script parses” but not “the script behaves”. A behavior assertion (the file written contains a literal \$(date), not its expansion) was missing.
- **Response.** Added behavior assertions to the subagent’s checklist. Heredoc now uses single-quoted delimiter ('EOF') which disables shell expansion inside the heredoc body.
- **Policy lesson.** “Verified” is a claim about behavior, not syntax. §3.3 (Logging and Monitoring) requires positive probes (sha256sum, REST call, process count) — assertions about behavior — not just “log shows X”.

Example 9 — 2026-08-22 SSH key chmod drift (LEARNINGS #93)

- **What happened.** /root/.openclaw/*.key files occasionally lose the 0600 mode (e.g., after copy between WSL and native Linux). SSH then refuses to use the key.
- **Response.** Periodic chmod 0600 is part of the host bootstrap script.
- **Policy lesson.** Host-level state (file modes, key ownership) is operational state. Operations hygiene includes state assertion, not just file existence.

4. Responsibilities

Role	Responsibilities
Venkat Narasimha (Owner)	Approves this policy + exceptions. Approves all prod changes. Performs quarterly secret audit + access review. Final escalation on SEV-1/2. Owns the offsite backup VPS access.
Processbricks admin	Executes daily ops runbook at 08:30 IST. Performs monthly backup verification (restore + sanity query). Manages backup cron + scripts. Reviews weekly logs. First responder on SEV-3.

Role	Responsibilities
Subagents (automation)	Run heartbeat probes on schedule. Execute pre-flight checklist items. Auto-remediate known-safe failures (LEARNINGS #91 image prune). Surface unknown failures to Venkat within 1h. Never auto-fix on prod without approval.
All users	Report anomalies within 1h (per 01-info-security §3). Don't share credentials. Don't bypass MFA. Don't run ops commands against prod without authorization.
Vendors	Bound by contract to provide security advisories within 7 days of CVE disclosure (Frappe, ERPNext, HRMS, MariaDB, Redis).

5. Compliance Measurement

Check	Frequency	Owner	Source of truth
Backup SHA-256 cross-check	Daily	admin	../04-runbooks/04.2-daily-ops.md Step 2
Backup BACKUP_OK sentinel present	Daily	admin	/home/vijay/backups/logs/*.log last line
Backup slot freshness (≤ 6 h lag)	Daily	admin	ls -lt
Offsite rsync freshness (≤ 6 h lag)	Daily	admin	/home/vijay/backups/prod/SSH to offsite, list dir
Monthly restore drill (sanity query)	Monthly	admin	scratch MariaDB + SELECT COUNT(*)
Full DR drill	Quarterly	Venkat	08-business-continuity §3.4
tabError Log daily review	Daily	admin	tabError Log query
Cert expiry probe (≥ 14 days)	Daily	admin	openssl + heartbeat
Container RestartCount	Daily	admin	docker inspect
Disk space (main + offsite)	Daily	admin	df -h
Apps.txt modtime vs apps/ dir	Weekly	admin	stat + ls
CVE review (Frappe/ERPNext/HRMS)	Weekly	Venkat	upstream advisories
Log archive (30d hot → 1y compressed)	Weekly	admin	logrotate + gzip
Secret audit	Quarterly	Venkat	04-cryptography §5
Image prune (reclaimable)	Weekly Sunday	cron	LEARNINGS #91
pip-audit on haritha_hospital deps	On PR (future)	CI	pip-audit

Check	Frequency	Owner	Source of truth
Heartbeat run actually happened	Daily	subagent	heartbeat log
Cron line integrity	Weekly	admin	../04-runbooks/04.2-daily-ops.md §“Cron line integrity”

KPI dashboard (informal, not a Grafana board):

KPI	Target	Source
Offsite backup freshness	≤ 6h lag	rsync target timestamp
Failed backup slots per month	0	cron log sentinel
tabError Log spike events	≤ 1/week	tabError Log query
Unresolved SEV-1/2 incidents	0	Slack #ops / Telegram
Container restart loops	0 (prod)	docker inspect
Disk space (both VPSes)	≤ 85%	df -h
Patches applied within SLA	100%	patch tracker (future)
Post-mortem filed within 24h	100% (SEV-1/2)	docs/phase6/post-mortems/

6. Exceptions

1. **dev_backup.sh / qa_backup.sh / deverp_backup.sh pre-hardening.** Tracked as a known gap (§3a). Resolution: apply the prod_backup.sh hardening pattern in the next quarterly maintenance window (target: 2026-Q4). Until then, weekly manual `ls -lt` and `tail -5 <log>` review is the compensating control.
2. **No cold storage for backups (Backblaze B2 / S3 Glacier).** Offsite is one private VPS, not geographically distant. Tracked in 08-business-continuity §6 (future). Until then, the existing 3-2-1 (local + offsite + git remote for code) is the trust model.
3. **No formal docs/phase6/changes/ directory.** Convention exists; no files yet. Next prod change will create the first file; subsequent changes append.
4. **No CI-side CVE scanner.** Weekly manual review is the compensating control.
5. **HRMS pinned to v16.5.0 indefinitely** (LEARNINGS #44). Upgrade requires explicit Venkat approval + dry-run on dev first.
6. **All other exceptions** follow 01-info-security §6.

6a. Edge Cases & Decision Matrix

Specific scenarios that test the policy’s boundaries. Each entry includes the trigger, the decision, and the rationale.

Edge case 1 — Backup cron is in place but the script file is missing or non-executable

- **Trigger.** `crontab -l | grep backup` returns the entry, but `ls /home/vijay/scripts/qa_backup.sh` returns no result (script was accidentally deleted by a cleanup pass).
- **Decision matrix.**

Action	Allowed?	Why
Recreate the script from the latest git version + run a manual backup	YES	LEARNINGS #74 — script presence and cron presence are independent; restore both
Run crontab -r to clear and re-add later	NO	Defeats the purpose; cron will run the next slot's nothing
Just re-add the cron line, skip the manual backup	NO	Next slot may still fail if script is missing
Disable the cron until the script is restored	NO	Loses one slot of backups; better to recreate script

- **Default action.** Recreate the script from the git-tracked version (/home/vijay/frappeclaw/.../script). Run a manual backup. Verify offsite. Then verify cron line integrity per LEARNINGS #74 (all 6 checks pass).

Edge case 2 — Heartbeat subagent is unavailable (session limit, model outage)

- **Trigger.** It's 09:00 IST. The 08:30 heartbeat subagent didn't run — OpenRouter returned 429, or session quota hit, or the subagent session was killed.
- **Decision matrix.**

Action	Allowed?	Why
Manually run the daily ops runbook (10 min)	YES	Compensating control; same probes
Skip the heartbeat and assume "yesterday's probes are still valid"	NO	LEARNINGS #90 — carry-forward is dangerous for drift-prone metrics
Page Venkat	NO (yet)	It's not a SEV; just a missing probe. Document the gap.
Wait until tomorrow's subagent runs	NO	Loses one day of probes

- **Default action.** Admin (or Venkat) manually runs ../04-runbooks/04.2-daily-ops.md Steps 1-5 in ~10 min. Logs the manual run in the heartbeat log with a note: "08:30 IST subagent unavailable; manual run at 09:00 IST by ". Future: a crontab-based shell-script heartbeat as authoritative fallback (tracked in §3a Known GAPS).

Edge case 3 — Offsite VPS (venkat@135.125.196.35) is unreachable

- **Trigger.** SSH to offsite VPS times out. Last successful rsync was 4 hours ago.
- **Decision matrix.**

Hours unreachable	Action
0-4	Monitor; verify it's not local network. Check offsite VPS provider status page.
4-24	SEV-3. Alert Venkat. Defer non-critical offsite rsyncs. Local backups continue.

Hours unreachable	Action
24-72	SEV-2. Document in docs/phase6/09-compliance/exceptions/. Consider adding a second offsite (B2 / Wasabi).
> 72	SEV-2 with policy temporarily violated. Restore cadence resumes when offsite is back. Annual review asks “do we need a second offsite?”.

- **Default action.** Same as 01-info-security §6a Edge Case 5. Never silently let backups accumulate only locally — the 3-2-1 invariant must be restored or formally waived.

Edge case 4 — A security patch is published mid-payroll-week

- **Trigger.** A critical CVE for OpenSSL is announced on Tuesday. Payroll runs Friday-Saturday on prod.
- **Decision matrix.**

Action	Allowed?	Why
Apply the patch immediately to dev → QA → prod	NO (not on prod during payroll window)	Risk of regression > risk of CVE exploit window (≤ 7 days per §3.4.1)
Apply to dev/QA only, defer prod to Sunday	YES (preferred)	Compensates with non-prod validation; prod patch on Sunday post-payroll
Skip the patch entirely	NO	Violates §3.4.1 (security patches within 7 days)
Apply only to prod, skip dev/QA	NO	LEARNINGS #48 — every change goes through dev → QA → prod

- **Default action.** Apply to dev immediately. QA within 48h. Prod on Sunday maintenance window. Document the deferred-prod window as a temporary exception; the exception is renewed only if the CVE is re-rated during the deferral.

Edge case 5 — bench update triggers a migration that fails partway

- **Trigger.** `bench update --reset` on dev runs `frappe.patches.v16.add_some_field` which fails with `ALTER TABLE ... error 1091 (can't DROP ...)`. The migration is half-applied.
- **Decision matrix.**

Action	Allowed?	Why
Restore dev from the most recent backup	YES	LEARNINGS #79 — backup is the rollback path for migration failures
Try to revert the patch manually	NO	Migration state is opaque; manual revert is error-prone

Action	Allowed?	Why
Skip the failing patch and re-run bench update	RISKY	Patch state machine may not be in a known-recoverable position
Force bench update --reset --no-backup to retry	NO	Loses the rollback path

- **Default action.** Restore from backup per ../04-runbooks/04.3-disaster-recovery.md §“Partial recovery — single container, data intact”. Apply the patch in a separate transaction (e.g., bench migrate individually) to identify the failing patch. If the patch is upstream-broken, pin the prior version and file an upstream issue.

Edge case 6 — A new hire joins and needs SSH + DB access

- **Trigger.** Processbricks hires a new admin. They need SSH to the VPS, docker exec privileges, and DB read access for incident response.
- **Decision matrix.**

Step	Required
Provision per-person SSH key (ed25519, passphrase, mode 0600)	YES
Add public key to vi-jay@...:/home/vijay/.ssh/authorized_keys	YES
Provision tabUser on each env (dev/qa/prod) with role per 02-access-control §3.3	YES
Enroll in MFA (TOTP) before first login	YES (mandatory for any prod role)
Add to access register	YES
Grant docker group membership (for docker exec)	Conditional — only after Venkat approval for prod
Grant haritha_ro MariaDB user (read-only) for analyst queries	YES (separate from admin)

- **Default action.** Follow 02-access-control §3.4 Lifecycle. All 7 steps required before first prod access. Quarterly review re-verifies.

Edge case 7 — Backup encryption-at-rest is requested but not implemented (cross-link to §3.1.7)

- **Trigger.** A future auditor asks “where is the encryption-at-rest policy for backups?”. The answer today is “not implemented; tracked as future in 04-cryptography §3.6”.
- **Decision matrix.**

Action	Allowed?	Why
Document the gap honestly in §3a Known GAPS + audit response	YES	Transparency over silence
Implement age symmetric encryption immediately	NO (without Venkat approval)	Adds operational complexity (key management) that needs a design decision

Action	Allowed?	Why
Disable backups until encryption is implemented	NO	§3.1.1 — 3-2-1 mandatory; encryption is a separate concern
Rotate the offsite VPS to a provider with disk encryption	NO (without Venkat approval)	Hosting-provider change is an infra change per §3.2

- **Default action.** Document the gap. Plan implementation per 04-cryptography §3.6 future items. Compensating controls today: private offsite VPS + single-operator trust + access control (no anonymous read access to backup dir).

Edge case 8 — A new container is added to the fleet (e.g., a metrics container)

- **Trigger.** A future Prometheus + Grafana container is added to track container metrics over time.
- **Decision matrix.**

Step	Required
Pin image by digest	YES (per §3.4.2)
Add to asset-inventory.md (per 03-asset-management §3.1.2)	YES
Configure healthcheck + restart: unless-stopped (per MEMORY.md rule #7)	YES
Add to heartbeat probe list	YES
Configure log shipping (or accept local retention)	YES
Document access (who can docker exec it)	YES

- **Default action.** All 6 steps. Without healthcheck, the container is invisible to the heartbeat — exactly the failure mode 01-info-security §6a Edge Case 7 warns against.

7. Related Documents

- 01-info-security.md — Umbrella + exception flow + emergency-access pattern.
- 02-access-control.md — RBAC roles, access register, MFA enrollment.
- 03-asset-management.md — Asset inventory + classification drives what we back up.
- 04-cryptography.md — Backup encryption at rest (future), TLS for log shipping (future), secret storage.
- 06-communications-security.md — Network architecture + TLS termination (sibling policy).
- 07-incident-management.md — SEV classification + escalation (sibling policy).
- 08-business-continuity.md — DR + RTO/RPO targets (sibling policy).
- ../04-runbooks/04.2-daily-ops.md — Daily heartbeat probes.
- ../04-runbooks/04.1-deployment.md — Pre-flight checklist + post-deploy verification.
- ../04-runbooks/04.3-disaster-recovery.md — Full restore procedure.
- ../04-runbooks/04.4-incident-response.md — SEV ladder + triage flow.
- ../05-process/05.1-change-management.md — Change types, pre-flight, rollback levels.
- ../05-process/05.2-post-mortem.md — Post-mortem template + 2026-08-29 example.
- ../../../../learnings/LEARNINGS.md — Lessons #46, #48, #72, #74, #77, #78, #79, #80, #87, #88, #89, #90, #91, #93, #113, #114, #151, #153.
- ../../../../MEMORY.md — Tech stack, container names, DB names, backup cron schedule, offsite paths.

8. Revision History

Version	Date	Author	Changes
1.0	2026-08-29	venkat-narasimha	Initial

9. Implementation Checklist

Concrete actions derived from this policy. Owner initials: VN = Venkat Narasimha; PA = Processbricks admin. Status as of 2026-08-29.

Immediate (this week)

- ☐ **Create docs/phase6/changes/ directory** and the first per-env file structure. Owner: VN. Target: 2026-09-05. Status: Not Started.
- ☐ **Run manual pberpqa and pberpdev heartbeat probe** to verify dev/qa containers are also healthy (not just prod). Owner: PA. Target: 2026-09-05. Status: Not Started.
- ☐ **Verify the sentinel BACKUP_OK sha=... line is present** in prod_backup_cron.log for 2026-08-29 + 2026-08-30 slots. Owner: PA. Target: 2026-09-05. Status: Not Started.

Short-term (2026-Q3)

- ☐ **Harden dev_backup.sh, qa_backup.sh, deverp_backup.sh** with the same timeout 900 + \${PIPESTATUS[0]} + sentinel pattern as prod_backup.sh. Owner: PA. Target: 2026-09-30. Status: Not Started.
- ☐ **Add apps.txt modtime assertion to weekly cron** (per LEARNINGS #90). Owner: PA. Target: 2026-09-30. Status: Not Started.
- ☐ **Wire a crontab-based shell-script heartbeat** as the authoritative fallback for the subagent-driven heartbeat. Owner: PA. Target: 2026-10-15. Status: Not Started.
- ☐ **Implement pip-audit CI job** for haritha_hospital deps. Owner: PA. Target: 2026-10-15. Status: Not Started.
- ☐ **Document the offsite-VPS-down runbook** (cross-link to 01-info-security §6a Edge Case 5). Owner: VN. Target: 2026-09-30. Status: Not Started.

Medium-term (2026-Q4)

- ☐ **Add log shipping to long-term storage** (Backblaze B2 or a third log VPS). Owner: PA. Target: 2026-11-30. Status: Not Started.
- ☐ **Wire Frappe advisory-fetch + diff** as a weekly CI job for CVE monitoring. Owner: PA. Target: 2026-11-15. Status: Not Started.
- ☐ **Patch tracker** (simple spreadsheet or markdown doc) with SLA tracking per §3.4.1. Owner: VN. Target: 2026-10-31. Status: Not Started.
- ☐ **Add RestartCount > 0 alert for dev/qa schedulers** (not just prod). Owner: PA. Target: 2026-10-31. Status: Not Started.
- ☐ **HRMS upgrade dry-run** to v16.6.x (when upstream stable). Owner: VN. Target: 2026-12-15. Status: Not Started.

Long-term (2027+)

- ☐ **Backblaze B2 cold storage** for offsite backups (cross-link 08-business-continuity §6). Owner: VN. Target: TBD. Status: Not Started.
- ☐ **Encrypted backups at rest** with age (cross-link 04-cryptography §3.6). Owner: VN. Target: TBD. Status: Not Started.

- ❑ **Grafana + Prometheus** for container metrics (deferred — manual cadence OK for now). Owner: VN. Target: TBD. Status: Not Started.

Recurring verification (runs forever)

- ❑ **Daily heartbeat** (subagent at 08:30 IST — Steps 1-5 of ../04-runbooks/04.2-daily-ops.md). Owner: PA. Frequency: daily. Status: Done.
- ❑ **Daily backup SHA-256 cross-check** (Step 2 of daily ops). Owner: PA. Frequency: daily. Status: Done.
- ❑ **Daily cert expiry probe** (Step 5 of daily ops). Owner: PA. Frequency: daily. Status: Done.
- ❑ **Weekly cron line integrity check** (../04-runbooks/04.2-daily-ops.md §“Cron line integrity”). Owner: PA. Frequency: weekly. Status: Done.
- ❑ **Weekly log archive** (gzip + ship to archive/). Owner: PA. Frequency: weekly. Status: Done.
- ❑ **Weekly Sunday 04:00 IST image prune** (LEARNINGS #91). Owner: cron. Frequency: weekly. Status: Done.
- ❑ **Monthly backup verification** (sanity query on restored DB). Owner: PA. Frequency: monthly. Status: Done.
- ❑ **Quarterly full DR drill** (per 08-business-continuity §3.4). Owner: VN. Frequency: quarterly. Status: Not Started (first cycle Q4 2026).
- ❑ **Quarterly CVE review** (manual). Owner: VN. Frequency: quarterly. Status: Done.
- ❑ **Quarterly secret audit + access review**. Owner: VN. Frequency: quarterly. Status: Done.
- ❑ **Annual policy review** (re-read, increment version). Owner: VN. Frequency: annually. Status: Done (this revision).

Silent failure is the worst failure. Probe > carry-forward. Sibling steps are part of the change.